

BSI-/C5-orientiertes Betriebshandbuch

- **System:**** FastMCP-Harness in einer Cloudinfrastruktur
- **Geltungsbereich:**** Nginx, LiteLLM, FastMCP, getrennte Modellgruppen, PostgreSQL-Prompt-Registry und Evaluation
- **Zielgruppen:**** Plattformbetrieb, Security, Datenschutz, KI-Governance, Audit und Service Management
- **Status:**** technische Betriebsreferenz; keine formale BSI-C5-Testierung oder Zertifizierung
- **Version:**** 1.0

1. Zweck und Aussagegrenze

Dieses Handbuch beschreibt den sicheren und nachweisbaren Betrieb des FastMCP-Harness-Systems in einer Cloudumgebung. Es orientiert sich an BSI-Grundschutz, BSI C5, ISO/IEC 42001, ISO/IEC 27001/27002, DSGVO/BDSG und dem risikobasierten Ansatz des EU AI Act.

Die technische Umsetzung allein beweist keine Compliance. Eine formale Bewertung benötigt einen definierten Scope, Kontrollowner, Betreiberorganisation, Nachweise über einen Prüfzeitraum und gegebenenfalls eine unabhängige Prüfung.

2. Schutzziele und Schutzbedarf

Die folgenden Schutzziele sind verbindlich zu bewerten:

- **Vertraulichkeit:**** Prompts, Modellkonfigurationen, personenbezogene Daten, API-Keys und Evidence-Daten dürfen nur autorisierten Rollen zugänglich sein.
- **Integrität:**** Prompt-Versionen, Policies, Modellaliasse, Evaluationsergebnisse und Auditdaten müssen unverändert nachvollziehbar bleiben.
- **Verfügbarkeit:**** Gateway, FastMCP, Registry und Evaluation müssen gemäß festgelegten RTO/RPO wiederherstellbar sein.
- **Nachvollziehbarkeit:**** Jede sicherheits- oder freigaberelevante Aktion muss Actor, Zeitpunkt, Scope, Ergebnis und Korrelation-ID ausweisen.
- **Menschliche Kontrolle:**** KI-Ergebnisse dürfen keine ungeprüften produktiven Änderungen auslösen.

Der Schutzbedarf wird je Umgebung, Datenklasse und Verarbeitungsvorgang ermittelt. Produktive Daten und personenbezogene Daten dürfen nicht in Testdatensätzen oder lokalen Entwicklungsberichten erscheinen.

3. Sicherheitsorganisation und Rollen

Rolle	Verantwortung
Service Owner	Gesamtverantwortung für Zweck, Scope und Betrieb
Plattformbetrieb	Cloud, Container/Kubernetes, Netzwerk, TLS und Verfügbarkeit
FastMCP-Betrieb	Serverkonfiguration, Tools, Gateway-Anbindung und Laufzeit
KI-Governance	ISO-42001-Risiken, Modellprovenienz, Evaluation und Verbesserung
Security	Schwachstellen, Policies, Trivy, Incident Response und Freigaben
Datenschutz	DSGVO/BDSG, DPIA, Rechtsgrundlage, Löschung und Betroffenenrechte
Datenbankbetrieb	PostgreSQL-Rollen, Backup, Restore, Migration und Monitoring
Auditor	unabhängige Kontrolle und Nachweisprüfung

Privilegierte Rollen verwenden MFA, individuelle Konten, kurze Tokenlaufzeiten und regelmäßige Rezertifizierung. Gemeinsame technische Konten sind verboten.

4. Betriebsarchitektur

```
Benutzer
-> Nginx / TLS 1.3 / Rate Limit
-> LiteLLM / ACL / Token-Tracking
-> FastMCP bzw. Modellalias
-> getrenntes RAG- oder Coding-Backend

FastMCP
-> PostgreSQL Prompt Registry
-> Datensatz-Pipeline
-> Evaluation-Suite / unabhängige Richter
-> Evidence Bundle
```

Ollama-Backends sind nicht öffentlich erreichbar. RAG- und Coding-Backends verwenden getrennte Netzwerke, Volumes, Modell-Allowlisten und Ressourcen. Die aktuelle lokale Referenzumgebung arbeitet CPU-basiert; eine GPU-/ROCm-Produktionsfreigabe benötigt einen separaten Hardware- und Performancenachweis.

5. Identität, Zugriff und Secrets

- Benutzerzugriffe erfolgen über den freigegebenen Identity Provider.
- ServiceAccounts besitzen ausschließlich die benötigten Rechte.
- Nginx, LiteLLM, FastMCP und PostgreSQL verwenden getrennte Identitäten.
- PostgreSQL-Rollen sind mindestens in Lesen, Schreiben und Administration getrennt.
- Secrets werden aus Secret-/Key-Management bezogen.
- Secrets erscheinen nicht in Git, Images, Prompts, Logs, Terraform-Plans oder Evidence.
- Zugriffe, Rollenänderungen und Freigaben werden auditierbar protokolliert.

6. Netzwerk- und Transportsicherheit

- öffentliche Schnittstellen verwenden TLS 1.3;
- Zertifikate werden überwacht, erneuert und bei Bedarf widerrufen;
- Rate Limiting und Request-Größenlimits sind aktiviert;
- LiteLLM ist der einzige Modellgateway;
- Ollama ist nur aus dem autorisierten Backend-Netzwerk erreichbar;
- PostgreSQL ist nur aus dem FastMCP-/Registry-Scope erreichbar;
- Default-Deny und explizite Allow-Regeln begrenzen Netzwerkpfade;
- Cloud Security Groups, NetworkPolicies und Nginx-Regeln werden versioniert.

7. Prompt- und Modell-Governance

Die PostgreSQL-Registry unter `prompt-registry/schema.sql` verwaltet:

- KI-System-Inventar;
- Modellprovenienz und Modellgruppen;
- Prompt-Templates und unveränderliche Prompt-Versionen;
- Datensätze und Dataset-Versionen;
- Evaluation-Suites, Testfälle und Runs;
- Richterergebnisse und menschliche Freigaben;

- Evidence Bundles und Audit-Ereignisse.

Eine Prompt-Version durchläuft den Status draft, in_review, approved,

deprecated oder blocked. Nur approved darf produktiv verwendet werden.

Genehmigte Versionen werden technisch gegen nachträgliche Änderung geschützt.

8. ISO/IEC 42001-Betrieb

Für jedes KI-System werden Zweck, Owner, Risiko-Owner, Datenverarbeitung,

Modell, Aufsicht und Evaluationsstatus dokumentiert. Der Betrieb führt:

- KI-Risikoregister;
- Auswirkungs- und Missbrauchsbeurteilung;
- Evaluation von Qualität, Robustheit und Prompt-Injection;
- Nachweis menschlicher Aufsicht;
- Incident- und Abschaltprozess;
- Monitoring und kontinuierliche Verbesserung;
- Management- und interne Reviews.

Ein Harness-Exit-Code 0 ist nur ein technischer Kontrollnachweis und keine

ISO-42001-Zertifizierung.

9. EU AI Act

Die Risikokategorie wird für den konkreten Zweck und Einsatzfall bewertet.

Vor Freigabe sind mindestens zu dokumentieren:

- intended purpose;
- Prüfung verbotener Praktiken;
- Transparenzhinweis;
- menschliche Aufsicht;
- Protokollierung;
- Genauigkeit, Robustheit und Cybersicherheit;
- Verantwortlicher Betreiber und rechtliche Bewertung;
- technische Dokumentation und Änderungsverlauf.

10. DSGVO/BDSG

Bei personenbezogenen Daten werden Rechtsgrundlage, Zweckbindung,

Datenminimierung, Zugriff, Aufbewahrung, Löschung, Betroffenenrechte und

Drittlandtransfer bewertet. Roh-Prompts und Roh-Antworten werden standardmäßig nicht gespeichert.

PII- und Secret-Scans laufen vor einer Speicherung in Evidence Bundles. Berichte enthalten ausschließlich redigierte Metadaten, Hashes und notwendige Befunde.

Eine DPIA und ein Verzeichnis der Verarbeitungstätigkeiten werden erstellt, sofern die Bewertung dies erfordert.

11. Harness, Evaluation und Freigabe

Datensatz-Pipeline
-> Harness-Orchestrator

- > LLM / Applikation
- > unabhängige Evaluation / Richter
- > Evidence Bundle
- > menschliche Freigabe

Die Harness prüft Scope, Policies, Governance, Python/YAML, Trivy, Gateway, Modellgruppen und Read-only-Grenzen. Die Evaluation-Suite prüft unter anderem:

- Prompt-Injection;
- PII- und Secret-Redaktion;
- Halluzinationen;
- Tool-Allowlist;
- No-Mutation-Verhalten;
- Verfügbarkeit und sichere Fehler;
- Qualitäts- und Policy-Kriterien.

Der Richter darf nicht einfach das bewertete LLM selbst sein. Testdatensatz, Prompt-Version, Modellalias, Grader-Version und Ergebnisse werden miteinander verknüpft.

12. Lieferkette und Schwachstellen

- Container-Images stammen aus freigegebenen Quellen;
- Versionen werden gepinnt und möglichst per Digest referenziert;
- Trivy-Scan und SBOM sind vor Promotion verpflichtend;
- kritische ungeklärte Findings blockieren die Freigabe;
- Ausnahmeentscheidungen benötigen Owner, Begründung, Ablaufdatum und Freigabe;
- Abhängigkeiten werden über Lockfiles beziehungsweise Hashes kontrolliert;
- Build- und Release-Ereignisse werden auditierbar gespeichert.

13. Logging, Monitoring und Audit

Zu überwachen und revisionssicher nachzuweisen sind:

- Nginx-Zugriffe, TLS- und Rate-Limit-Ereignisse;
- LiteLLM-Routing, ACL-Verstöße und Tokenverbrauch;
- FastMCP-Toolaufrufe, Fehler, Laufzeit und Modellalias;
- PostgreSQL-Rollen, Migrationen und fehlgeschlagene Zugriffe;
- Backend-Verfügbarkeit und Modellfehler;
- Harness-, Evaluation-, Backup- und Restore-Ergebnisse;
- Security- und Datenschutzvorfälle.

Logs enthalten keine Secrets, Rohprompts oder unnötigen personenbezogenen Daten.

Retention und Löschung werden je Datenklasse festgelegt.

14. Backup, Restore und Notfallmanagement

Täglich und vor kritischen Änderungen werden mindestens Prompt-Registry, Evidence-Referenzen, Governance-Konfiguration, Auditdaten und Gateway-Policies gesichert. Backups sind verschlüsselt, versioniert und unveränderlich.

Ein Restore erfolgt zunächst isoliert. Danach werden Schema, Freigaben,

Prompt-Versionen, Evidence-Hashes und Auditbezüge geprüft. RPO und RTO werden gemessen und dokumentiert.

Bei einem Incident:

- Änderungen und Promotionen stoppen;
- Scope und betroffene Daten feststellen;
- Logs und Evidence sichern;
- Security, Datenschutz und Service Owner informieren;
- Abschalt- oder Restore-Runbook ausführen;
- Ursache, Auswirkungen und Maßnahmen dokumentieren;
- Wiederfreigabe menschlich genehmigen.

15. Change- und Release-Management

Jede Änderung benötigt:

- Ticket und Risiko;
- Git-Commit und Review;
- Harness- und Evaluationsergebnis;
- Trivy-/SBOM-/PII-Nachweis;
- Backup-/Restore-Bewertung;
- menschliche Freigabe;
- Evidence Bundle.

Nicht freigegeben werden Änderungen bei fehlendem Owner, unbekanntem Scope, fehlendem Backup, ungeklärten kritischen Findings, offenen Governance-Gates oder direktem Produktions-Apply.

16. Regelmäßige Kontrollen

Intervall	Kontrolle
jeder Change	Harness, Evaluation, Security- und Datenschutz-Gates
jedes Release	Image-Digest, Trivy, SBOM, Prompt-/Modellprovenienz
täglich/definiert	Backup, Monitoring und Alarmierung
monatlich	Rollen, ACLs, Retention und offene Findings
quartalsweise	Restore-Test, Evaluation-Review und Governance-Review
jährlich	Incident-/Notfallübung, Managementreview, unabhängige Kontrolle

17. Offene Zielarchitektur

- produktives TLS und Cloud-Authentifizierung;
- reale LiteLLM-ACLs, Tokenlimits und Retention;
- produktive getrennte Modell-Backends;
- GPU-/ROCM- oder verbindliche CPU-Leistungsfreigabe;
- Datensatz-Pipeline und unabhängige Richter-Suite;
- PII-/Secret-Scan und Evidence Bundle als CI-Pflichtgate;
- echte Owner, Rechtsbewertungen und Aufbewahrungsfristen;
- PostgreSQL-TLS, Produktionsrollen, Backup und Restore.

18. Aussagegrenze

Dieses Handbuch ist eine technische Betriebsreferenz. Es ersetzt keine ISO-42001-Zertifizierung, EU-AI-Act-Rechtsprüfung, DSGVO-Bewertung, BSI-/C5-Testierung, Cloud-Provider-Vertragsprüfung oder unabhängige Auditierung.